Enterprise Information Security Program Plan

For

Alpha Community College

Hao Nguyen, Lizeth Delgado, Sampada Parajuli, Tanner Weaver & Yedidhyah Alturi

Department of Information System Security, Collin College

ITSY 2341: Security Management Practices

Manny Hameed

December 12th, 2024

1. Introduction 2

1.1 - Purpose 3

1.2 - Scope 3

1.3 - Background 3

1.4 - Assumption/Constrains 3

2. Alpha Community College Organization 3

2.1 - Vision 3

2.2 - Mission 5

2.3 - Core Values 6

2.4 - Board of Trustees' Strategic Business Objectives 7

3. Legal and Privacy 7

3.1 - Legal Relevant Laws, Statues, or Regulations. 7

3.2 - CISO interfacing with the CPO 12

3.3 - PIA or DPIA 13

4. Information Security 14

4.1 - Key Enterprise Team Members 14

4.2 - RACI Matrix for Key Team Members' Responsibilities 26

4.3 - RACI Matrix for Security Functions 27

4.4 - Information/Data Classification Scheme 28

4.4.1 Risk: Inadequate Data Classification Schema 30

4.5 - Data Retention Schema 30

4.6 - Magnetic Remanence Schema 31

4.7 - Aligning Information Security Program with the Business 33

4.8 - Security Frameworks 35

4.8.1 - Security Frameworks Other Than Control Frameworks 35

4.8.2 - Security Control Framework 37

4.9 - GAP Assessment 39

4.10 - Risk Management Program 41

4.11 - Metrics 43

4.12 - Highest Prioritized Risks 45

4.12.1 - Risk 1: Inadequate Data Classification Schema 45

4.12.2 - Risk 2: Incomplete Information Security Assessment 45

4.12.3 - Risk 3: Uneducated Staff 45

4.12.4 - Risk 4: Absence of Established Baseline Security Controls 46

5. Information Security Policies, Procedures, Standards, or Processes 46

6. Programs 47

6.1 - Program 1: Data Classification 47

6.1.1 - Risks Addressed - Inadequate Data Classification Scheme 48

6.1.2 - Initiation Rationale 48

6.1.3 - Program Practices 48

6.1.4 - Expected Outcomes 55

6.1.5 - Implementation Timeline 56

6.2 - Program 2: Security Assessment Implementation 56

6.2.1- Risk Addressed: Incomplete Information Security Assessment 56

6.2.2 - Initiation Rationale 57

6.2.3 - Program Practices 58

6.2.4 - Expected Outcomes 59

6.2.5 - Implementation Timeline 62

6.3 - Program 3: Security Education, Awareness, and Training 64

6.3.1 - Risks Addressed 64

6.3.2 - Initiation Rationale 64

6.3.3 - Program Activities 64

6.3.4 - Expected Outcomes 68

6.3.5 - Implementation Timeline 69

6.4 - Program 4: Establishing Baseline Security Controls 69

6.4.1 - Risks Addressed 70

6.4.2 - Initiation Rationale 70

6.4.3 - Program Activities 71

6.4.4 - Expected Outcomes 74

6.4.5 - Implementation Timeline 75

Acronyms and Abbreviations 76

Definitions 79

Works Cited 80

Collaboration 89

1. Introduction

1.1. Purpose

Alpha Community College's information security policy focuses on protecting critical data from loss, damage, or inappropriate use. Also educating faculty, staff, students, and visitors about the importance of protecting data generated, accessed, transmitted, and stored by the College. To identify strategies that should be in place to protect the confidentiality, integrity, and availability of college data and comply with local and federal regulations. Policies in this document are intended to ensure that the College maintains appropriate functional access for students, faculty, and staff while adhering to security standards.

1.2. Scope

This policy applies to all individuals who are given access to Alpha Community College's computer equipment, systems, and networks owned or operated by Alpha Community College, including, but not limited to, the following, whether full-time or part-time: faculty, staff, and students. This policy applies to information, electronic and computing devices, and network resources to conduct Alpha Community College business or interact with internal networks and business systems, whether owned or leased by Alpha Community College, the individual, or a third party.

1.3. Background

Alpha Community College is located in north Texas, having campuses located throughout the DFW Metroplex with approximately 50,000 students. The students at Alpha Community College have the opportunity to achieve a two-year Associates of Applied Science (AAS) degree across multiple disciplines or earn a certificate through the workforce programs. Alpha Community College has transfer agreements between 5 community colleges across Texas,

allowing students from these institutions to obtain a four-year degree in either a Bachelor of Science (BS) or a Bachelor of Applied Technology (BAT). Some of the currently offered programs are below

- Bachelor of Science degrees are in the following disciplines:
- Nursing
- Dental Hygiene
- Digital Analytics

i) Bachelor of Applied Technology granting degrees are in the following disciplines:

- Cybersecurity
- Resource Protection

Alpha Community College maintains a strong relationship with local businesses wherein special projects deal with respective business proprietary information that could include a business's trade secret data or information. These special projects allow Alpha Community College students and faculty to work with local businesses in supporting or contributing to new project initiatives. These local businesses give students skills in solving technical challenges, perform assessments, and other such items. Local company relationships between higher education and local businesses offer a unique opportunity wherein learned theory is put into real-world practice resulting in realized business solutions.

Alpha Community College is also home to a centrally located health care center near the largest campus, providing health care to Alpha Community College students, faculty, full and part-time employees, and their families. The health care center provides care to local neighborhood families on an appointment basis. Alpha Community College's Health Center is located near Central University. Central University's Medical and Dental students and faculty

provide medical and dental care services at Alpha Community College's Health Center. Alpha Community College Students matriculating in Nursing or Dental Hygiene provide health or dental care services under Alpha Community College, or Central University's Medical and Dental licensed faculty supervision.

1.4. Assumptions/Constraints

It is anticipated that this information security program will be accepted and supported by Alpha Community College employees, contractors, business partners, and third-party vendors. The executive leadership team will be accountable for guaranteeing that all parties are acquainted with this program through the onboarding processes, periodic training, and access to repositories with distributed documentation.

2. Alpha Community College Organization

2.1 - Vision

Alpha Community College serves the Dallas/Fort Worth (DFW) area as a premier learning institution where student success exemplifies the strength of a diverse, DFW Metroplex community college.

Alpha Community College specific vision ideals are as follows:

- A college environment that values and supports a culturally diverse and intellectually dynamic community and prepares students for global citizenship
- Respected liberal arts and sciences with transfer programs that facilitate student preparation for the baccalaureate experience

- Respected Bachelor of Science (BS) granting programs in Nursing, Dental Hygiene, and Digital Analytics serving health care and business needs of DFW and surrounding areas; and Bachelor of Applied Technology (BAT) granting programs in Cyber Security and Resource Protection serving business needs of DFW and greater surrounding areas.
- Superior career programs that prepare students to meet current and evolving labor market needs.
- Innovative developmental and literacy programs that prepare students for more advanced educational and training opportunities.
- Agile programs that meet the needs of employers and emergent workforce development initiatives.
- Responsive continuing adult and community education programs that enhance and encourage individual growth and development.
- An engaged and excellent faculty, staff and administration that enable students to meet their full potential.
- A teaching and learning environment that exemplifies ongoing and productive communication and collaboration across the institution and with local businesses.
- An innovative health and dental programs leveraging local Medical and Dental School support providing health and dental services at Alpha Community College's Health Center.
- Strong and mutually beneficial partnerships with public and parochial schools, community organizations and governmental agencies that model effective community-based educational programs.

- State-of-the-art technology is employed to enhance teaching and learning.
- Accessible and affordable education is designed to optimize opportunities for student participation.
- A supportive learning community that uses learning outcomes to measure success and guide innovative curricular and program improvements to meet individual and group needs.

2.2 - Mission

Alpha Community College's mission statement is as follows:

Alpha Community College is an open-admission, associate degree (with Bachelor of Science (BS) and Bachelor of Applied Technology (BAT) programs) granting institution which provides access to higher education for all who may benefit. Its programs of study in the liberal arts and sciences, career technologies, and basic academic skills provide a coherent foundation for college transfer, employment and lifelong learning. The College serves the Dallas/Fort Worth (DFW) area by preparing its students to be informed and concerned citizens, active participants in the cultural life of the DFW Metroplex, and enabled to meet the changing needs of business, industry and the professions. To help address broad economic, cultural and political concerns of the DFW area and beyond, the College draws together students from a wide range of ages and backgrounds and seeks to provide the programs and support they need to achieve their goals.

The College seeks to create a caring environment which is intellectually and culturally dynamic and encourages all students to achieve:

- Greater insight into their strengths, needs and aspirations, and greater appreciation of their own cultural background and experience.

- Increased awareness and appreciation of a diverse world where all are interdependent.
- Heightened curiosity and active interest in intellectual questions and social issues.
- Improved ability to pursue paths of inquiry, to interpret and evaluate what is discovered, and to express reactions effectively.
- Self-fulfillment based on service to others, preparation for future work and study, and enjoyment of present challenges and accomplishments.

3. Legal and Privacy

3.1 - Legal Relevant Laws, Statues, or Regulations.

The legal Relevant laws, status and regulation lists relevant laws, agenda, certificates, act constitutions, codes and requirements enacted, established, issued or considered applicable by the jurisdiction of Texas government body and internationally, applicable to Alpha Community College.

Health Insurance Portability and Accountability Act (HIPAA)

U.S. Department of Health and Human Services Defines HIPPA as a law that "protects patients' health information" (PHII) and implements "standards for electronic health information" (U.S. Department of Health & Human Services, 2020). The law stated assumes that the patients have the right to protect their personal records whether it be electronic, oral or written.

Alpha Community College has to directly comply with the HIPAA as they have heath care center on their campus and on their online platform. The healthcare center provides services

to its students, faculty, staff and members of the community. This gives them access to sensitive health information which can be vulnerable to unauthorized access if not regulated appropriately.

Family Educational Rights and Privacy Act (FERPA)

Regulation under Sections 444 of the General Education Provision Act (GEPA), FERPA "is a federal law enacted in 1974 that protects the privacy of the student education records" (CDC, 2024). FERPA applies to every level of educational institution, ranging from elementary to post-secondary inclusive to private and public institutions or a combination of both (CDC, 2024).

Alpha Community College is a higher public education institute and must comply with FERPA. It also applies to international students attending the institute. The law protects student records by giving rights to the student's parents or the students (if 18 or older), to view or make any modifications if the records prove to be inaccurate or misleading (U.S. DEPARTMENT OF EDUCATION, 2024).

Furthermore, the law states that the educational institutes have the right to disclose student's educational record without consent but need written permission from the parents or eligible students to release the said information (CDC, 2024).

Gramm-Leach-Bliley Act (GLBA)

The GLBA Act's privacy requirement draws attention to financial institutions to "disclose their policies and practices" to protect the integrity, security and confidentiality of any Personally Identifiable Information about the consumers.

Alpha Community College is a financial institute that oversees financial transactions like student loans, payments, check cash services, financial aid, faculty payrolls and other finance related activities therefore comply by the act's Safeguards Rule and Privacy Rule.

The safeguards rule and the privacy rule mandate the development of a clear and comprehensive information security program to protect customer information and proper security and management of non-public information (NPI).

Texas Identity Theft Enforcement and Protection Act (ITEPA)

Most states have their version of data privacy and security act. Residing in North Texas, Alpha Community College abides by the policies put forward by the state of Texas. Texas Identity Theft enforcement and Protection Act (ITEPA) mandates personal information for protection from threats and breaches. The Office of Attorney General of Texas (20-) proclaims "ITEPA requires businesses to implement and maintain reasonable safeguard to protect sensitive personal information from unlawful use of disclosure" (Identity Theft Enforcement and Protection Act | Office of the Attorney General, n.d.).

The act requires the establishment owing the license of the sensitive personal information to disclose the breach to the party affected and the Office of the Attorney General. The act further regulates proper disposal of personal information by rendering it unreadable or indecipherable.

Payment Card Industry Data Security Standard (PCI-DSS)

Alpha Community College acknowledges and practices cardholder industry standards for their card owners. The policy protects transactions made through credit, debit and cash card. The institute also protects misuse of any personal information of the cardholders.

Children's Internet Protection Act (CIPA)

Enacted to protect minors from harmful content, Alpha Community College considers underage students' exposure to unsafe online environment seriously. As the institute enrolls students under 18 for their dual-enrollment program and in some cases, regular college program, Alpha Community College is directly influenced by the CIPA. As a community college, the college library serves the public and has partnerships with public libraries receiving E-rate fundings.

Alpha Community College understands the implications of the act and complies with the technology protection measure. The measure includes filtering access to data that is (a) obscene; (b) child pornography; or (c) harmful to minors.

The institute facilities supervise, monitor online activities of minors, and educate them about appropriate behaviors online. Cyberbullying, hacking, unauthorized access of campus resources are not tolerated and can be subjected to campus rule violation following necessary procedures and can also lead to student status termination.

International Laws

General Data Protection Regulation (GDPR)

GDPR Art. 4(1) identifies personal data as any information that is linked or relevant to the identifiable natural person. The institute members accessing the site from a place that is a member of European Union (EU) is subjected under GDPR and is recognized and practiced by Alpha Community College.

Personal data can include any information that's directly or indirectly assumes students' identity. This data includes but is not limited to name, address, different forms of identification number, online identifier, societal or cultural identity, number plate and phone number.

Under GDPR, Alpha Community College students can exercise data protection by either modifying or erasing personal data. However, Alpha Community College can practice exceptions under following circumstance:

- Not applicable to individuals who are not citizens of the EU countries
- Right of access, rectification and restriction (Articles 15-18) if the use of data is scientific and research based in nature
- The party in question misuses institute services

Personal Information Protection and Electronic Documents Act (PIPEDA)

The Office of the Privacy Commissioner of Canada describes PIPEDA as a "set of ground rules for how private-sector organizations collect, use, and disclose personal information in the course of for-profit, commercial activities" (Office of the Privacy Commissioner of Canada, 2024).

Alpha Community College is required to abide by PIPEDA if the institute platform is accessed from Canada. The end users must consent before collection and use of the data. Parties that fall under this category have the right to know what happens to their personal information as categories under PIPEDA.

Data not covered by PIPEDA:

- Business contact information

- Provincial, territorial government and their agents
- Personal information handled by the government organization listed under privacy act.

3.2 - CISO interfacing with the CPO

Alpha Community College understands and abides by data privacy standards set by various governing bodies. CISO and CPO are essential management aspects and must collaborate to maintain the privacy and integrity of Alpha Community College's information. The Chief Information Security Officer (CISO) is responsible for protecting the college's data and systems and other digital assets.

CPO will look over all the data and personal information the college has in both technical and legal approach and implement necessary standards to make sure the privacy and confidentiality is maintained. They may also look over how the data is collected, used, stored and keep up with new policies, standards and regulations.

CISO and CPO collectively are responsible for college's privacy compliance and data protection. This can include but is not limited to setting data policies, standards and implementation of regulations. CPO must oversee the implications set by the CISO and see that it aligns with overall objective of the college. Both parties must have consecutive meetings and must discuss issues or changes related to the agenda that they have put forward in terms of data security. If needed, the CPO can create a team that can ensure effective human resources, timely operation and generate insightful reports that can be implemented as an executive business strategy.

3.3 - PIA or DPIA

Privacy Impact Assessment (PIA) is required to be thoroughly implemented complementarily to the personal data protection measures. Alpha Community College handles a significant amount of personal data on their students, staff and faculties. The handled data is required to remain transparent to their owners (i.e., the owners of the data have the right to know how it is being used), must abide by the legal standards and compliance, protected from potential security threat and abide by the data management standard set-in place. The objective set by the U.S Department of Education characterizes PIA as a "tool" for making a "system design" based on series of informed decisions based on risk and options on mitigating those risks (Privacy Impact Assessments (PIA), 2023). Our institution intends to prioritize the objective to efficiently handle the data.

Data Protection Impact Assessment (DPIA) is a requirement under laws like GDPR and is implemented by Alpa Community College specifically for projects with sensitive information and higher risks. The nature of the information is usually tied to ethnicity, genetic information, biometric for the purpose of uniquely identifying an individual, health concerns, ancestry and origin and sexual orientation. The DIPA is further implemented in the case of major technological changes, which requires series of movement and storage concerns for sensitive information. The procedure is implemented to mitigate major risk and improve data security and governance.

4. Information Security

4.1 - Key Enterprise Team Members

- Board of Trustees
- Alpha Community College President (CEO)

- Chief Information Officer (CIO)
- Chief Information Security Officer (CISO)
- Data Protection Officer (DPO)
- Department Heads includes:
    - Head of Campus Provosts
    - Head of Human Resources
    - Head of Health Center
- Director of Information Technology (IT) includes:
    - Security Architect
    - Security Analysts
    - Compliance Specialists
    - Security Engineers
- General Counsel includes:
    - Chief Privacy Officer
    - Legal Counsel
- Campus Financial Officer
- Internal Audit
- Security Steering Committee

Board of Trustees

The Alpha Community College board of trustees' primary responsibilities are protecting the organization's assets and funds. Plus, they are overseeing the activities, policies, and overall direction of the Alpha Community College. As the highest and final authority for an organization, trustees hold the final decision for all strategic oversight, policy development,

financial stewardship, although some of those decisions can be assigned to some executive leaderships (CEO) (Kaminsky, 2023).

Alpha Community College President (CEO)

Leadership and Strategy

- Defines and communicates the Alpha Community College's vision, mission, and strategic goals
- Ensures that all institutional activities align with the mission of providing high-quality, accessible education
- Leads the development and implementation of the college's strategic plan
- Analyzes internal and external trends to position the college for long-term success
- Develops, recommends, and enforces policies that guide the college's operations and governance
- Collaborates with the Board of Trustees to ensure policies reflect the institution's needs

Operational Management

- Oversees academic programs and ensures they meet student and community needs
- Promotes innovation in teaching, learning, and curriculum development
- Develops and manages the college's budget to ensure financial health and sustainability
- Secures funding through grants, partnerships, and efficient resource allocation
- Recruits, develops, and evaluates senior leadership and faculty
- Fosters a positive, inclusive, and collaborative organizational culture
- Ensures compliance with local, state, and federal regulations
- Anticipates and mitigates risks, including cybersecurity, legal, and financial risks

Governance and Collaboration

- Reports to and works closely with the Board of Trustees, providing updates on college performance and strategic initiatives
- Implements board decisions and ensures the institution operates within its governance framework
- Engages with faculty, staff, and students to foster shared governance and inclusivity
- Acts as the primary decision-maker for the college while considering stakeholder input

Chief Information Officer (CIO)

The Chief Information Officer (CIO) of Alpha Community College plays a vital role in managing the institution's technology infrastructure, aligning IT strategy with institutional goals, and ensuring that technology supports academic and administrative functions effectively.

Key roles and responsibilities of a CIO:

- Responsible for all software, hardware and infrastructure, as well as with the overall management of Alpha Community College’s data.
- Develops and implements a comprehensive IT strategy that aligns with the college's mission, vision, and goals.
- Oversees data governance policies to ensure the accuracy, security, and ethical use of institutional data.
- Implements and maintains robust cybersecurity protocols to protect sensitive data and systems.
- Prepares and tests incident response plans to address potential cybersecurity threats.

(Woollacott, 2024).

Chief Information Security Officer (CISO)

CISO focuses on leading and developing the Alpha Community College's information security program. This involves protecting the college's assets, applications, systems, and technology while enabling and advancing business outcomes. Other responsibilities include:

- Ensures that the organization complies with relevant laws, regulations, and standards, such as GDPR, HIPAA, or ISO 27001
- Responsible for identifying potential security threats and vulnerabilities within the organization's systems and processes.
- Implementing risk management frameworks: This includes adopting frameworks (e.g., NIST, ISO 27001) to evaluate and mitigate risks, balancing security controls with business needs.
- Developing incident response plans: The CISO oversees the creation and execution of plans to respond to security breaches, ensuring the organization is prepared for data breaches, cyberattacks, and other incidents.
- In the event of a breach or attack, the CISO leads the response efforts, coordinates with internal and external teams, and helps mitigate the impact.
- Ensures the deployment and operation of critical security tools, including firewalls, intrusion detection/prevention systems, endpoint protection, etc.
- Ensuring that the security team has the skills, tools, and resources needed to effectively monitor and protect systems.

- Responsible for fostering a culture of security within the organization, often through training programs and awareness campaigns to reduce human error and insider threats.
- Managing the cybersecurity budget and ensuring resources are allocated appropriately for risk mitigation, compliance, and technology upgrades.
- Works with IT, legal, HR, compliance, and other departments to integrate security into the organization's daily operations and projects.
- The CISO provides regular reports to senior leadership, ensuring they understand current risks, progress on initiatives, and potential areas of concern.
- Develops security policies, procedures, and guidelines to govern how data is protected and how security risks are managed across the Alpha Community College.

(Cisco, 2022), (Fimlaid, 2024).

Data Protection Officer (DPO)

A Data Protection Officer (DPO) is a key role in an organization responsible for ensuring that the organization complies with data protection laws and regulations, such as the General Data Protection Regulation (GDPR) in the EU, as well as other relevant data privacy laws. The DPO plays a critical role in managing and protecting the personal data of customers, employees, and other stakeholders. Other roles include:

- Provides advice and guidance to the organization on how to comply with privacy laws, including conducting data protection impact assessments (DPIAs) and ensuring data processing activities are lawful.
- The DPO creates, implements, and maintains internal data protection policies that align with legal requirements and industry best practices.

- Responsible for continuously monitoring the organization's data processing activities to ensure compliance with internal policies and external regulations.
- Conducts regular audits and reviews of data protection practices, systems, and processes to identify weaknesses or areas of non-compliance.
- The DPO plays a key role in responding to data breaches, ensuring that the organization takes immediate action to mitigate the impact and notify the relevant authorities and affected individuals in accordance with legal requirements.
- Ensures that the organization keeps an accurate record of the personal data it processes, including details on how the data is collected, used, stored, and shared.
- Helps map the flow of personal data within the organization and with third parties, ensuring data is processed in a secure and compliant manner.

(European Data Protection Supervisor, 2024), (IT Governance, n.d).

Head of Campus Provosts

- Lead the effort to define the college's vision and mission
- The campus provost is a member of the Council of Provosts, which advises the administration and Academic Senate on campus-wide undergraduate education matters. These include, but are not limited to, general education, academic engagement, advising, academic integrity, honors programs, and student retention.
- Foster a collaborative and supportive environment that encourages meaningful scholarly interactions between students and faculty associated with the college.
- Ensure equal employment opportunities and take the lead in promoting the college's commitment to achieving affirmative action goals for academic and staff positions.

- Collaborate with college faculty to recruit new members, and, when requested, provide evaluations of faculty contributions to the college for personnel decisions.
- Organize faculty discussions focused on the academic role of the college, including sponsoring courses, setting graduation requirements, and creating curricula that complement departmental and divisional programs.
- Work closely with the student affairs team, particularly the college administrative officer to strengthen collaboration and support for students.
- Seek opportunities for divisions and colleges to collaborate on complementary academic initiatives that enhance undergraduate education, such as interdisciplinary research and educational programs tied to the college's mission.

Head of Human Resources

- Provide strategic and operational advice to the dean, vice president, and department heads. Collaborate on human resources initiatives and tasks, which includes engagement, policy compliance, risk management, access, opportunity and diversity.
- At the college or division level, provide guidance, review, approval, and supervision for HR policies, procedures, resources, and transactions; support culture and workplace consistent with the Alpha Community College mission, vision, and core values.
- Examine, evaluate, and project trends in college and division workforce data while keeping financial constraints in mind. Create plans to deal with and document areas of concern and need.
- Provide strategic leadership for HR programs and services at college/division level, such as performance management, organizational effectiveness, compensation, recruitment and retention.

- Act as an active liaison between Alpha Community College Human Resources and the college, division, or department(s). They are usually the first person that college HR contacts for routine or non-transactional issues.
- Inform data-driven decisions by analyzing, interpreting, and forecasting college/division workforce data trends.
- Ensure college/division and department policies, practices and programs meet legal/regulatory standards and conform with Alpha Community College policies.
- Review, guide, approve, advise and oversee HR policies, practices, resources, and transactions at the college/division level.

(IOWA, 2021).

Head of Health Center

- The Head of the Health Center at Alpha Community College focuses on ensuring the physical and mental well-being of the college's students, faculty, and staff, which requires strategic oversight, clinical expertise, and a collaborative approach to support the health and safety of the campus community.
- Develop and implement health center policies, procedures, and programs aligned with the college's mission.
- Oversee daily operations of the health center, including staff management and resource allocation.
- Monitor compliance with local, state, and federal healthcare regulations (e.g., HIPAA, FERPA).
- Manage budgets, contracts, and procurement for health-related services and supplies.

- Ensure the provision of high-quality primary care, mental health services, and health education.
- Oversee emergency response protocols and coordinate care for medical or mental health crises.
- Develop programs to address the unique health needs of community college students, including mental health, nutrition, and stress management.
- Collaborate with campus departments to integrate wellness initiatives into academic and extracurricular activities.
- Act as a resource for health-related concerns, providing guidance to students, parents, and staff.

(Medicat, 2024), (Online Masters in Public Health, n.d.).

Director of Information Technology (IT)

The Director of Information Technology (IT) at Alpha Community College manages and advances the college's technological infrastructure to support academic and administrative functions. The responsibilities of this role include:

- Developing and aligning IT strategies with the institution's goals, focusing on transformation and innovation to enhance educational and operational outcomes.
- Overseeing the college's technology infrastructure, including networks, hardware, and software, ensuring reliability, scalability, and security.
- Establishing and enforcing robust security measures to protect institutional data, maintaining compliance with regulatory standards.

- Leading IT teams, managing vendor relationships, and ensuring the delivery of IT services effectively and efficiently.
- Providing technical support and training to faculty, staff, and students.
- Overseeing IT projects, including system upgrades, new implementations, and disaster recovery planning, ensuring timely and cost-effective execution. (Kirtland Community College, n.d.).

General Counsel

- Acting as a trusted advisor to the college's leadership, including the board of trustees and senior administrators, on legal risks and strategic decisions impacting the college.
- Ensuring that the institution follows all applicable laws.
- Handling legal conflicts and offering advice during crisis.
- Managing legal aspects of contracts, partnerships, and agreements involving the college.
- Focusing on preventative measures, such as training staff on compliance issues, avoiding potential litigation and fostering a culture of ethical decision-making.

(Crosse, 2024)

Campus Financial Officer (CFO)

The Campus Financial Officer (CFO) at higher education institutions plays a vital role in overseeing the financial health and sustainability of the institution. Key responsibilities include:

- Developing and implementing strategies to ensure the institution's financial goals align with its mission and long-term plans. This involves overseeing operational budgets, financial forecasting, and risk management plans.

- Establish financial policies that ensure compliance with regulatory standards and best practices in higher education finance.
- Ensuring that budgets reflect institutional priorities and support strategic objectives. The CFO is involved in capital budgeting and planning to allocate resources effectively and sustainably.

(Chief Financial Officer, n.d.).

Internal Audit

- Assess the Alpha Community College's risks and the efficiency of its risk management efforts.
- Evaluate whether institutional policies, processes, and systems are aligned with regulatory and compliance standards, identifying areas for improvement to strengthen governance frameworks.
- Evaluate internal control and make recommendations on how to improve.
- Identifying shortfalls or gaps in processes.
- Promote ethics and help identify improper conduct.
- Assess institutional risks, including financial, operational, and strategic risks, and recommend mitigation strategies.
- Conducts regular assessments of internal controls, ensuring efficient use of resources and safeguarding against fraud or mismanagement.
- Investigate fraud.
- Provides regular reports to the finance committee or board, outlining findings and progress in improving controls, compliance, and risk mitigation strategies.

(Bucklin, 2024), (Klaino, 2024).

Security Steering Committee

The Information Security Steering Committee (ISSC) at Alpha Community College establishes and manages the institution's cybersecurity framework. This committee should represent a broad range of stakeholders to ensure a well-rounded approach to security, including IT leadership, legal counsel, HR representatives, internal auditors, faculty, and student representatives.

- Develop, approve, and periodically review system-wide security policies, standards, and guidelines.
- Ensure alignment with applicable regulatory frameworks (FERPA or HIPAA).
- Promote a culture of security awareness among students, faculty, and staff.
- Act as a liaison between technical teams and senior leadership, ensuring transparency in security decisions.
- Identify, prioritize, and monitor information security risks.
- Advocate for budgetary and project resources to mitigate critical risks.

(Pearson IT Certification, 2014).

Information Security Steering Committee Members

- Head of Campus Provosts
- Head of Human Resources
- Chief Privacy Officer
- Chief Information Officer (CIO)

- Chief Information Security Officer (CISO)
- Chief Security Officer
- Chief Privacy Officer
- Internal Audit
- Head of College Health Center

(Hameed, 2024).

4.2 - RACI Matrix for Key Team Members' Responsibilities

Information Security Tasks	President (CEO)	CISO	CIO	DPO	Department Heads	Director of IT	Security Architect	Security Analysts	Compliance Specialists	Security Engineers	General Counsel	Campus Financial Officer	Internal Audit	Security Steering Committee	Board of Trustees
Governnance	R	A/R	R	C	C	C	C	C	C	C	C	C	R	R	R
Policies, Process, and Standards	A	R	R	C	C	I	C	I	R	I	C	I	I	C	C
Strategy	A	R	R	C	I	I	C	I	I	I	I	I	I	C	C
Risk Assessments - Definition	C	R	R	C	I	I	C	R	C	I	I	I	I	C	I
Risk Assessments - Execution	C	R	R	C	I	I	C	R	C	I	I	I	I	C	I
Management	C	R	R	C	I	I	C	C	R	I	I	I	I	C	C
Architecture	C	R	R	C	I	I	A	C	I	I	I	I	I	C	I
Technology	C	R	R	C	I	A	C	R	C	I	I	I	I	C	I
Engineering	C	R	R	C	I	I	C	R	C	A	I	I	I	C	I
Dispute Resolution	C	R	R	C	I	I	C	I	C	I	A	I	I	C	I

Table 1: RACI Matrix

R = Responsible: The individual(s) completing the task or ensuring the work gets done.

A = Accountable: The person ultimately answerable for the task and its success.

C = Consulted: Those whose provide input based on either how it will impact their future project work or their domain of expertise on the deliverable itself.

I = Informed: Those who need to be kept up to date on progress or decisions.

(RSS, n.d).

4.3 - RACI Matrix for Security Functions

Security Function	CISO's Team	CIO's Team	Other Team
Develop Security Policies	R	C	A (Other Team)
Conduct Risk Assessments	R	C	A (Other Team)
Information Technology Security Policy	R	C	A (Other Team)
Incident Response Management	R	C	A (Other Team)
Security Configuration Baseline Standards	R	C	A (Other Team)
Security Standards	R	C	A (Other Team)
Access Control Standard	R	C	A (Other Team)

Table 2: RACI Matrix for Security Function

4.4 - Information/Data Classification Scheme

An effective information/data classification scheme is essential for managing and protecting the sensitive information held by Alpha Community College. This scheme categorizes data based on its sensitivity and the impact of unauthorized disclosure, ensuring that appropriate security measures are applied to each category. The classifications typically include Public, Internal, Confidential and Restricted (Brook, 2023).

- Public Data: Information that is legal to share on the internet and is intended for public access.

- Internal (Private) Data: Information intended for internal use within the college. This may include internal memos, policies, and operational procedures that do not require confidentiality but should not be disclosed externally.
- Confidential Data: Sensitive information that requires protection from unauthorized access. This may include student records, employee files, and certain financial data.
- Restricted Data: Highly sensitive information that, if disclosed, could cause significant harm to individuals or the organization. This may include electronic protected health information (E-PHI), financial aid data, and proprietary information related to business entities.
- Critical Infrastructure Data: Information related to the college's IT infrastructure, security protocols, and disaster recovery plans. This data is crucial for maintaining the operational integrity of the college.

The following data types are classified as Confidential:

- Personal Identifiable Information (PII): Social Security Numbers, Driver's License Numbers, Financial Account Numbers, etc.
- Protected Health Information (PHI) and Electronic Protected Health Information (EPHI): Medical Records, Health Insurance Details, Diagnosis and Treatment Information, etc.
- Financial Information: Bank Account Details, Credit/Debit Card Numbers, Tax Records, Payroll Information, etc.
- Legal or Regulatory Data: Contracts and Agreements, Litigation-related Documents, Regulatory Filings.
- Business-sensitive Information: Strategic Plans, Market Research, Confidential Business Proposals, Merger and Acquisition Documents.

- Authentication and Security Data: System Credentials (Passwords, PINs, Access Tokens), Encryption Keys, Network Configuration Details.
- Restricted Research Data: Sensitive academic or industry research with access limitations. (Brook, 2022).

Data types are classified as Restricted:

- Intellectual property (IP) and trade secrets
- Personally identifiable information (PII)
- Protected health information (PHI)
- Tax-related data
- Cardholder data

(Satori, 2023).

4.4.1 Risk: Inadequate Data Classification Schema

The lack of a robust data classification schema at Alpha Community College presents significant risks to the organization. Without a clear framework for categorizing data based on sensitivity and importance, sensitive information may be mishandled, leading to potential data breaches, unauthorized access, and non-compliance with regulatory requirements.

As a result, Alpha Community College will face the risk of exposing sensitive information (personal data, financial and health information). Plus, the organization will severe penalties for failing to comply with laws (HIPAA, GDPR), hurt their own reputation, disrupt the operation and loss of trust.

4.5 - Data Retention Schema

The data retention schema: Duration of time that specific types of data must be kept before being deleted or archived. The length of the retention period varies depending on the type of data, its sensitivity, regulatory requirements, and institutional policies (Qureshi, 2020).

Record Category		Retention Period	
		Active Period	Archive Period
1	**Personal Identifiable Information (PII)**	3 – 5 years	2 – 3 years
2	**Personal Health Information (PHI)**	5 – 7 years	3 – 5 years
3	**Payment Card Industry (PCI) Data and Logs**	1 – 2 years	1 – 2 years
4	**Security Audit Logs**	1 year	1 – 2 years
5	**Tax Records**	5 – 7 years	3 – 5 years
6	**Medical Records**	5 – 7 years	3 – 5 years
7	**Employee Records**	3 – 5 years	2 – 3 years
8	**Student Records**	3 – 5 years	3 – 5 years

9	**Email and Communication Records**	2 – 3 years	1 – 2 years

Table 3: Data Retention

4.6 - Magnetic Remanence Schema

Magnetic Remanence Schema: Set of policies and procedures used to address the risk of the residual representation of data that remains on magnetic storage devices after data has been erased. This schema ensures that sensitive or classified information is properly handled and securely destroyed to prevent unauthorized recovery or access. (*Data Remanence - an Overview | ScienceDirect Topics*, n.d.).

Alpha Community College should follow the guidance in NIST Special Publication 800-53, which emphasizes the importance of securely sanitizing digital media. This involves using approved tools, methods, and procedures to eliminate sensitive data effectively. The college is required to document, track, and validate media sanitization or destruction processes, and periodically test these methods to confirm their effectiveness.

Additionally, digital media must be sanitized or destroyed prior to disposal or external reuse that will be governed and categorized by the data classification schema in section 4.4 to prevent unauthorized access to any residual data. This approach ensures robust protection against data breaches from discarded or repurposed media. (Kissel, Scholl, Skolochenko, & Li, 2006).

Classification	Data Disposal Procedure
Confidential/Restricted	**Sanitization Method:** Use data-wiping software compliant with standards like NIST SP 800-88 Rev. 1 to overwrite data multiple

	time. For magnetic storage, consider degaussing to eliminate residual magnetism. **Physical Destruction:** Shred, crush, or incinerate media to ensure complete destruction (e.g., using a professional shredding service or disintegrator).
Private	**Sanitization Method:** Use single pass overwriting tools or system utilities for data wiping. **Physical Destruction:** Shred printed documents and destroy digital media when no longer required.
Public	Data can typically be deleted using normal methods, such as formatting or simple file deletion. But if leaving to the College's control, all data deemed public in nature will be subject to cryptographic erase.

Table 4: Data Disposal

4.7 - Aligning Information Security Program with the Business

Information Security Program (ISP) is compulsory and necessary to support and defend Alpha Community College. Aligning the Information Security Program with the college not only protects the organization's information assets by improving security posture, but also supports business continuity, growth, and innovation. It is not seen only as a responsibility, but also as an institution's practice to prevent unauthorized access and data breaches.

Therefore, Alpha Community College will appoint Security Steering Committe (Section 4.1) to secure, maintain the system. Plus, they will develop reliable, as well as cost-effective strategies to protect the organization's data. The Committee will use the RACI from section 4.2 to help them identify their responsibilities.

The Committee will function as a supporter to the Alpha Community College by collecting information related to medical from the department heads and business regarding security affairs. They should follow the principles in the table below to have the best result. (University, 2022).

Principle	Objective
Focus on the business	Ensures information/cyber security is integrated into essential business activities
Deliver quality and value to stakeholders	Ensure information/cyber security delivers value and meets business requirements
Comply with relevant legal and regulatory requirements	Ensure statutory obligations are met, stakeholder expectations are managed and civil or criminal penalties are avoided
Provide timely and accurate information on security performance	Support business requirements and manage information risks
Evaluate current and future information threats	Analyze and assess emerging information/cyber security threats so that informed, timely action to mitigate risks can be taken
Promote continuous improvement in information/cyber security	Reduce costs, improve efficiency and effectiveness and promote a culture of continuous improvement in information/cyber security

Information Security Governance. By Krag Brotby

Copyright© 2009 John Wiley & Sons, Inc

Table 5: Principles to Support the Business

The CISO and CPO will use that information to form security strategies with the Commitee to ensure the project goals will align and help to defend the business.

Principle	Objective
Adopt a risk-based approach	Ensure risks are treated in a consistent and effective manner
Protect classified information	Prevent classified information (e.g., confidential or sensitive) being disclosed to unauthorized individual.
Concentrate on critical business applications	Prioritize scarce information/cyber security resources by protecting the business applications where a security incident would have the greatest business impact
Develop systems securely	Build quality, cost-effective systems upon which business people can rely (e.g., that are consistently robust, accurate and reliable)

Information Security Governance. By Krag Brotby

Copyright© 2009 John Wiley & Sons, Inc

Table 6: Principles to Defend the Business

4.8 - Security Frameworks

Security frameworks are structured guidelines and best practices designed to help organizations manage and improve their cybersecurity posture. They provide a roadmap for identifying risks, implementing security measures, and ensuring compliance with regulations (Kirvan & Granneman, 2021).

For Alpha Community College, the best frameworks are a hybrid of NIST CSF, ISO/IEC 27001, NIST 800-53, and CIS Control. This will ensure that Alpha Community College complies with all requirements and outlaws' potential risks and liabilities.

4.8.1 - Security Frameworks Other Than Control Frameworks

In addition to control frameworks, Alpha Community College will use non-control security frameworks to help our overall security strategy, risk management, and organizational practices. These frameworks focus on governance, compliance, and best practices, aiding our broader security objectives.

NIST Cybersecurity Framework (CSF)

Governance:

- Provides a structure to build on and manage risks by prioritizing a strategic decision-making method. Organizes the structure in 5 core functions, Identify, Protect, Detect, Respond, and Recover.
- Promotes a culture within the organization's cybersecurity to prioritize a continuous improvement which allows flexibility while dealing with any potential threats.

Compliances:

- Aligns with standards and regulations regarding federal and state regulations. It aids the organization to meet other industry regulations like HIPPA, FERPA, and PCI DSS.
- Designed to help the organization to align with requirements like the Texas Cybersecurity Act.

Best Practices:

- Guidance and direction to adapting an overall cybersecurity program that is both flexible and comprehensive.
- Follows a risk-based approach, prioritizing threats that hold a more severe consequence.
- Maintains more than just the technology side of cybersecurity but also governance, risk management and incident response.

(NIST, 2024; Claroty, 2023; Spakowski, 2023).

ISO/IEC 27001

Governance:

- Provides an Information Security Management System (ISMS) which will integrate the cybersecurity governance with the organization's business operations and ensures that the security of the data is looked at like a business priority and beyond just a security priority.
- Also maintains continual improvement withing the structure to adapt it to the threats and risk over time.

Compliances:

- Recognized globally, making it valuable to the organizations and its reputation, also very essential when dealing with international students or partners. Also complies with regulations like GDPR and HIPAA.
- Overall ensure that the college is taking the correct measures and meeting proper standards to make it safe for internation students and information.

Best Practices:

- The practices make ISMS effective and establish clear roles and responsibilities.
- Along with that there is a constant improvement which helps with risk assessments and audits

(ITG, n.d.; Kost, 2024; ISO, n.d.).

4.8.2 - Security Control Framework

Security control frameworks are essential for Alpha Community Colleges to establish and implement adequate security measures within the organization. They will provide structured guidelines and best practices to help manage and mitigate security risks and ensure compliance with industry standards.

CIS Control (Center for Internet Security)

Governance:

- Provides detailed steps to ensure that the IT systems and data are secure. Easy to implement into our system. By prioritizing asset management, vulnerability management and incident detection it established a governance that is efficient and effective.
- Monitors the security baseline of security controls which ultimate leads to an easier way to demonstrate cybersecurity maturity to stockholders and overseers.

Compliances:

- Addressed important factors like data protections, network security, and incident response helping the overall compliance standards.
- HIPAA, FERPA and PCI DSS require the organization to have certain security practices which are also addressed by the CIS controls.
- Simplifies the security assessments which makes it easier to track security progress of managing the audits.

Best Practices:

- Practices are listed and are very clear what is the highest priority making it efficient when it comes to maximizing the impact out of the available resources.
- The first few practices/controls create a foundational security which allows the organization to be effective in case of limited resources
- Creates a culture within the organization to take a more hands-on approach with security issues, prompting action like fixing vulnerabilities and closing endpoints

(Rapid7, n.d.; Kiteworks, n.d.; CIS n.d.; Verve n.d.).

NIST 800-53

Governance:

- Assures that the security system is aligned with the goals of the organization and supports through providing security controls that support factors like risk management.
- It's good for large organizations like our college because it has a complex security need as well as its priority to work with the organization's risk appetite.

Compliances:

- Helps organizations that handle health records and financial information to comply with the federal and state. Also aligned with standards like FISMA.
- Essential for an organization aiming to set and maintain high security standards, also can be essential when working withing contracts that require specific cybersecurity details.

Best Practices:

- Provides several impactful controls regarding security management, access control, continuous monitoring, and incident responses. This is important for an organization that wants to build a security environment that is highly efficient

(Apptega, n.d.; CyberSaint, n.d.; Gracy, 2024).

4.9 - GAP Assessment

The GAP Assessment evaluates the organization's security practices against industry standards and requirements. This will zone in on any weak points within the practices and identify potential

improvements. Ultimately, to prevent any other vulnerabilities, policies, procedures, technologies, and user awareness are reviewed and critiqued (*Cybersecurity Gap Analysis*, n.d.).

Step 1: Current State

The initial step that must be taken to assess the gaps is to assess the current state of the organization, including the organization's current resources, the practices and processes along with the outcomes. This step includes assessing what the goal state is and seeing the difference between the current and goal state.

Step 2: Implement SMART Goals

A SMART goal is a goal that is specific, measurable, achievable, relevant and time bound. Using this structure allows the organizations to be clear and straightforward with the goal state that is desired to reach. It is vital to continuously look at the goals and change them if needed throughout and not just once.

Step 3: Identify the Gaps

After knowing where the organization needs to be, you need to evaluate your organization for "external and internal factors" thoroughly and Identify gaps in performance, market, profit and manpower.

Step 4: Close the Gaps

Create a roadmap with checkpoints of monthly and quarterly to guarantee the organization is on the right path and is monitoring it. In this roadmap it's important to identify what causes the gaps and what is required to reach the goal state, so this includes the resources, processes and the outcomes.

Following these steps will ultimately lead to increased efficiency and effectiveness, enhanced decision making leading to better strategic planning which will improve the satisfaction of students, partner and other clients or relations. (Childs, 2023).

4.10 - Risk Management Program

A Risk Management Program is set in place to limit and find any hidden risks. Risk assessment, threat intelligence, and vulnerability management are used to mitigate risks based on potential harm. This is in place to constantly review risks so that threats are dealt with before any data loss or breaches (Knowles, 2021). Alpha Community College will be using NIST RMS, a 7-step process to approach risk management (NIST, n.d.).

Step	Purpose	Outcome
Prepare	Aims to ensure that all levels of the organization are prepared to manage risk regarding security and privacy.	• Risk management roles identified • Risk management strategy mapped out • Risk tolerance identified • Risk Assessment • Continuous monitoring • Controls identified
Categorize	Assess the adverse impact on organization risk management processes and tasks. This is done through evaluating the potential loss in confidentiality, integrity, and availability	• Characteristics of the system is documented • Information and system categorized

	of systems, as well as the information they process, store and transmit.	
Select	Select the controls that are needed for the system and organization to be secure from the risks.	• Selected control baselines • Controls categorized as system-specific, hybrid, or common • Security and privacy plans needed for the selected controls.
Implement	Implement the controls	• Controls implemented into the security and privacy plans.
Assess	Assess the controls, monitor and inspect if they are properly implemented and operating along with getting the outcomes wanted.	• Assessment team • Security and privacy plans assessment plan • Controls assessment plan • Reports and documentation of assessment • Updates and Development if needed to implement change.
Authorize	Set accountability, by getting authorization from a senior official.	• Authorization Package • Risk Determination mapped out along with risk responses • System is authorized and approved (can be denied)

Monitor	Manage a continuous monitoring of the structure and the operation to ensure everything is playing its role correctly to aid to the risk management.	• Operation continuously monitored • Continuous monitoring of the effectiveness • Reported and documented • Continuous authorization along to ensure everything is approved.

Table 7: Risk Management Program

4.11 - Metrics

Metrics like KPIs will be implemented to track the overall efficiency of the security program. This would include incident response time, the number of incidents, compliance audit results, user participation in training, and the rate of recommended security controls. The point is that gathering this data will aid in making decisions that need to be taken to improve the security program (Tunggal, 2023).

Alpha Community College will use a scorecard method to ensure everything is being tracked and continuously monitored. All results will be reported for authorization and approval. The scorecard includes domain, performance indicator, Target/Goal, measurement method, frequency of review, trend and highlights (insights).

The KPI's are categorized in five domains: incident detection, system security, data protection, user awareness, policy compliance and program effectiveness (Security Scorecard, 2024; NIST, n.d.).

Incident Detection

- Number of Security Incidents Detected

- Mean Time to Detect (MTTD)
- Mean Time to Resolve (MTTR)

System Security

- Percentage of Systems with Up-to-Date Patches
- Unauthorized Access Attempts Blocked
- Network Downtime Caused by Incidents

Data Protection

- Compliance Rate with Data Classification Policy
- Number of Data Breaches Reported

User Awareness

- Cybersecurity Training Completion Rate
- Number of Phishing Emails Reported

Policy Compliance

- Audit Findings Resolved on Time
- Compliance with Texas Cybersecurity Act

Program Effectiveness

- Percentage of Baseline Security Controls Implemented
- Risk Reduction Rate

Example

Domain	Performance Indicator	Target/Goal	Measurement Method	Frequency of Review	Trend	Highlights (Insights)
Incident Detection	Number of Security Incidents Detected		Incident reports from SIEM tools	Monthly		
	Mean Time to Detect (MTTD)		SIEM logs and incident tracking	Monthly		
	Mean Time to Resolve (MTTR)		Incident response logs	Monthly		
System Security	Percentage of Systems with Up-to-Date Patches		Patch management system reports	Monthly		
	Unauthorized Access Attempts Blocked		Firewall and IDS/IPS logs	Weekly		
	Network Downtime Caused by Incidents		Network uptime reports	Monthly		
Data Protection	Compliance Rate with Data Classification Policy		Data classification audit results	Quarterly		
	Number of Data Breaches Reported		Incident response reports	Monthly		
User Awareness	Cybersecurity Training Completion Rate		Training platform completion data	Quarterly		
	Number of Phishing Emails Reported		Simulated phishing campaign data	Quarterly		
Policy Compliance	Audit Findings Resolved on Time		Audit tracking system	Quarterly		
	Compliance with Texas Cybersecurity Act		Security assessment reports	Annually		
Program Effectiveness	Percentage of Baseline Security Controls Implemented		Security program progress reports	Monthly		
	Risk Reduction Rate		Risk assessment reports	Annually		

Table 8: Example of Scorecard (Metrics)

4.12 - Highest Prioritized Risks

These are the main risks affecting the college's critical areas that might be the most vulnerable. It is important to allocate our resources from the most severe to the least so that we are efficient with our resources (The risks below can be moved, there can be new ones added or removed).

4.12.1 - Risk 1: Inadequate Data Classification Schema

- Asset Affected: Sensitive Data, Student and/or Faculty E-PHI data

- Threat: Unauthorized access/Misuse of data, Non-compliance with privacy laws and regulations
- Vulnerabilities: No structured classification which leads to a higher chance of procedures of handling the data which can lead to exposure of the sensitive data
- Impact: Data Breaches, Legal Issues, Harm to reputation
- Time Period: 7 Months/Ongoing

4.12.2 - Risk 2: Incomplete Information Security Assessment

- Asset Affected: Overall Security (policies + practices), Sensitive data, financial assets
- Threat: Potential threats are internal and external which can include hackers, third-party service providers, and employees
- Vulnerabilities: Not meeting standards/ Not understanding the security vulnerabilities
- Impact: Cyber Attacks, penalties, Reputational Harm (example – stockholders)
- Time Period: 8-9 Months/Ongoing

4.12.3 - Risk 3: Uneducated Staff

- Asset Affected: Overall Structure and Integrity
- Threat: Human Error/policy non-compliance
- Vulnerabilities: Lack of training create a system that can get exploited through staff and human error
- Impact: increases the chances of data breaches and unauthorized access
- Time Period: 10-12 Months/ Ongoing

4.12.4 - Risk 4: Absence of Established Baseline Security Controls

- Asset Affected: Overall Network and IT Infrastructure.

- Threat: Potential internal and external threats, which can include employees, contractors, third-party risk, and hackers.
- Vulnerabilities: Lack of access control list (ACL), monitoring, incident response, and endpoint protection.
- Impact: Data breaches, legal repercussions, operational disruption, and long-term costs.
- Time Period: 5-6 Months/Ongoing.

5. Information Security Policies, Procedures, Standards, or Processes

Rank the following in order of most to least priority and explain why each item is in that order: Data Classification Standard, Information Security Policy, System Security Steering Committee Charter, Access Control Policy, Acceptable Use Policy, Cyber Risk Management Standard, Third Party Vendor Management Policy, Incident Management Policy, Privacy Policy, Non-Disclosure Agreement and training.

- Information Security Policy: Sets a foundation and structure for all the security practices and standards for the community college.
- Access Control Policy: Protects the system and data by setting authorization to only those that need to be for that data, preventing any unauthorized access within.
- Incident Managment Policy: In case there is a security incident, there will be a structure, and planned procedures to respond and recover from it as quickly and efficiently as possible minimizing any damage and downtime.
- Cyber Risk Management Standard: Identify and prioritize risks using resources to mitigate threats effectively.

- Data Classification Standard: Categorizing data by the level of importance to make sure it is prioritized in case of a threat.
- Privacy Policy: Personal and sensitive data complies with all privacy laws.
- Acceptable Use Policy: A guideline for the users/employees that establishes what is acceptable use of the resources.
- Non-Disclosure Agreement and Training: Guarantees by legal holding that employees and other parties protect confidentiality and are educated and trained in the policies that uphold this.
- Third Party Vendor Management Policy: Managment of any risks that are associated with vendors and partners.
- System Security Steering Committee Charter: Guides the security strategy and any decision-making processes.

6. Programs

6.1 - Program 1: Data Classification

The Data Classification Program is intended to provide Alpha Community College with a comprehensive view of relevant risks, threats, vulnerabilities, an implement effective data classification practices and policies compliant with data privacy protection laws and regulations to secure data collected from students, faculty member, and external business entities.

6.1.1 - Risks Addressed - Inadequate Data Classification Scheme

Alpha Community College collects, processes, and analyzes electronic protected health information (E-PHI), student information (especially foreign students (mainly from the European Union

(EU) and Canada), and those from California or New York), and external business entities' proprietary and trade secret information without the means to effectively classify and secure it.

As a result, the college risks potential threats such as the misuse of sensitive student, faculty member, stakeholder, and business partner information, unauthorized access to this information, and non-compliance with international data privacy protection laws and regulations.

Ultimately, these potential threats could result in data breaches, operational disruptions, financial penalties, legal and criminal liability, and reputational damage (Alder, 2024).

6.1.2 - Initiation Rationale

Implementation of the Data Classification Program will provide a comprehensive view of relevant risks, threats, and vulnerabilities and allow the college to effectively classify and secure student, faculty member, stakeholder, and business partner information, reducing the likelihood of potential threats and the impact of them.

6.1.3 - Program Practices

6.1.3.1 - Risk Assessment

It is necessary to conduct a risk assessment to identify the location, type, sensitivity, and priority of the data the college handles, compliance requirements, threats, vulnerabilities, risks, and implement effective security controls. The risk assessment should consist of the following 8 key steps:

6.1.3.2 - Data Discovery

Identify structured and unstructured data across the college, including data spread across databases, cloud storage services, files like emails and PDFs, and other sources (Fitzgerald, 2024).

6.1.3.3 - Identify Data Types

The college has identified various data types that are not addressed by the current data classification scheme, such as E-PHI, student information, and external business entities' proprietary and trade secret information.

6.1.3.4 - Assess Data Sensitivity and Priority

In accordance with the data classification levels outlined in Section 4.4 - Information/Data Classification Scheme, this section will assess the specific risks associated with each level:

- Public Data: This data presents little to no risk, as it is intended for public use.
- Internal (Private): This data presents a moderate risk if handled inappropriately, as it could result in operational disruptions, competitive disadvantages, data breaches, unauthorized access, and reputational damage.
- Confidential: This data presents a high risk if handled inappropriately, as it could result in operational disruptions, data breaches, reputational damage, invasion of privacy, unauthorized access, financial penalties, and legal and criminal liability.
- Restricted: This data presents an extreme risk if handled inappropriately, as it could result in operational disruptions, data breaches, reputational damage, invasion of privacy, identity theft, personal financial losses, unauthorized access, financial penalties, and legal and criminal liability.
- Critical Infrastructure Data: This data also presents an extreme risk if handled inappropriately and carries similar risks to restricted data.

(Alder, 2024).

6.1.3.5 - Determine Legal and Regulatory Compliance Requirements

Currently, Alpha Community College maintains compliance with two data privacy protection laws:

- Children's Online Privacy Protection Act of 1998 (COPPA)
- Family Educational Rights and Privacy Act of 1974 (FERPA)

However, the organization needs to determine and comply with laws and regulations that address the following:

- E-PHI
- Student information
- External business entities' proprietary and trade secret information

6.1.3.6 - Identify Threats and Vulnerabilities

Vulnerabilities such as weak passwords and IT settings, IT misconfigurations, excessive administration and access rights, unmanaged exposed assets, unpatched applications or systems, and unprotected or insufficiently protected endpoints should all be identified (Nagarajan, 2024).

Additionally, threats such as malware, phishing, exploit kits, Distributed-Denial-of-Service (DDoS) attacks, SQL injections, and insider threats should also be identified (Nagarajan, 2024).

6.1.3.7 - Risk Analysis and Prioritization

Regarding the Data Classification Program, the college currently faces three major risks:

- Misuse of data
- Unauthorized Access
- Non-compliance with privacy laws and regulations

Utilizing the Risk Matrix below, the college can effectively and efficiently categorize each risk based on their likelihood and overall impact on the organization.

	Impact:	Very Low	Low	Medium	High	Very High
Probability	Very High	Moderate	Severe	Severe	Critical	Critical
	High	Sustainable	Moderate	Severe	Critical	Critical
	Medium	Sustainable	Moderate	Moderate	Severe	Critical
	Low	Sustainable	Sustainable	Moderate	Severe	Critical
	Very Low	Sustainable	Sustainable	Sustainable	Moderate	Severe

Table 9: Risk Matrix

6.1.3.8 - Evaluate and Implement Security Controls

Implementation of effective security controls requires the college to first evaluate existing security controls, including physical security, access controls, network security, encryption, data handling procedures, auditing and monitoring policies and processes, incident response measures, training and awareness (IBM, 2022; What are Data Security Controls?, 2024).

6.1.3.9 - Monitor and Document Findings

Findings should be documented in a report that contains sections dedicated to the identification and prioritization of assets, current and potential threats and vulnerabilities, risk evaluation, existing and recommended security controls, review schedule, and responsibilities.

It is recommended that the college conducts a risk assessment at least every 6 months due to the sensitive nature of the information it handles.

6.1.3.10 - Data Classification Policy

a) Purpose

The purpose of this policy is to establish a framework to effectively classify and secure student, faculty member, stakeholder, and business partner information based on sensitivity, the risks they present, and overall value to Alpha Community College (*Data Classification Policy Template*, n.d.).

b) Scope

This policy applies to any form of information handled by the college, including any physical documents or digital data (*Data Classification Policy Template*, n.d.).

c) Roles and Responsibilities

Data Owner – The person responsible for the collection and maintenance of the data handled by their department or division. Responsibilities include:

- Review and categorization
- Assignment of sensitivity labels
- Data compilation
- Data classification coordination
- Data classification compliance (in conjunction with the DPO)
- Data access (in conjunction with the CISO)

Chief Information Security Officer (CISO) - The person responsible for the protection of data, applications, systems, and technology while overseeing the college's cybersecurity strategy. Responsibilities include:

- Access controls
- Monitoring activities
- Compliance (in conjunction with the DPO)
- Data validation
- Data backups
- Data restoration
- Audit reports
- Secure storage
- Data access (in conjunction with the data owner)

Data Protection Officer (DPO) - The person responsible for ensuring the college complies with data privacy protection laws, regulations, management and protection of student, faculty member, stakeholder, and business partner information. Responsibilities include:

- Compliance (In conjunction with the CISO)
- Data classification compliance
- Monitoring activities
- Audit reports
- Data restoration (in conjunction with the CISO)

Users - Responsible for data interacted with, accessed, or used with permission from the data owner and must comply with the Data Classification Policy (*Data Classification Policy Template*, n.d; Durham-Hutchins, 2024).

d) Handling Procedure

Data owners should review each piece of data they are responsible for and assign a data type based on the criteria outlined in Section 4.4 - Information/Data Classification Scheme.

Each piece of data will be categorized based on their assigned data type and given 1 of 5 sensitivity labels detailed in Section 4.4 - Information/Data Classification Scheme.

The CISO will apply appropriate security controls to protect each piece of data in accordance with their assigned sensitivity label, while the DPO ensures compliance with data privacy protection laws and regulations (*Data Classification Policy Template*, n.d).

e) Review and Update

This policy should be reviewed annually and updated accordingly to retain compliance with data privacy protection laws, regulations, and alignment with business changes (*Data Classification Policy Template*, n.d).

f) Training and Awareness

Staff should be educated on the purpose of the risk assessment (Including the location, type, sensitivity, and priority of data types, vulnerabilities, threats, risks, and security controls), data classification policy (Including the roles and responsibilities, handling procedures, and security controls), and the implementation steps of each.

Training should be delivered through online courses, videos, case study analysis and should be conducted on an annual basis.

g) Continuous Improvement

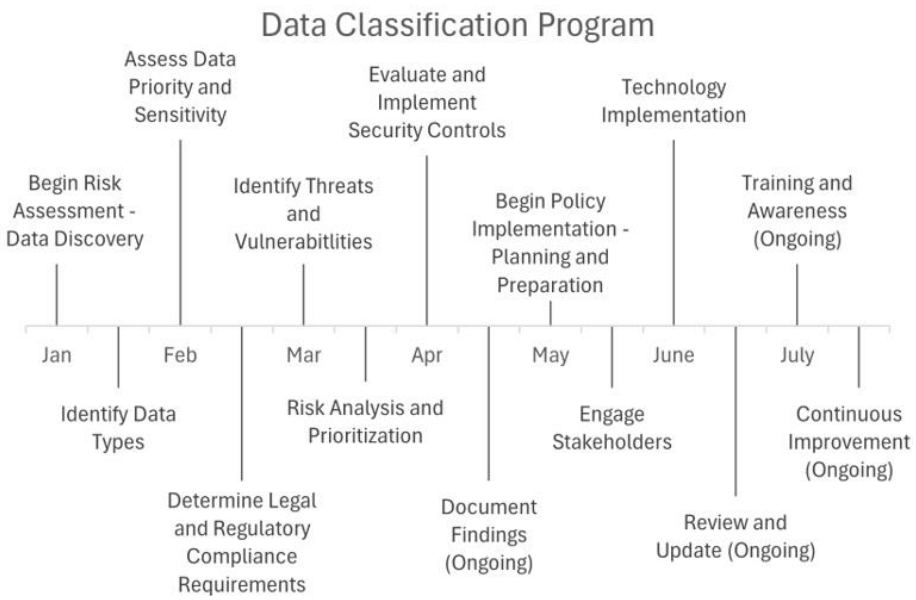
Key Performance Indicators (KPIs) should be implemented to measure the effectiveness of the Data Classification Program and identify any improvement opportunities.

Additionally, surveys and questionnaires should be offered each quarter to gather feedback from faculty members, stakeholders, and business partners.

6.1.4 - Expected Outcomes

The Data Classification Program is expected to provide Alpha Community College with a comprehensive understanding of relevant risks, threats, and vulnerabilities, and enhance student, faculty, stakeholder, and business partner information management and compliance with data privacy protection laws and regulations.

6.1.5 - Implementation Timeline



Timeline 1

6.2 - Program 2: Security Assessment Implementation

Alpha Community College presently uses the NIST Cybersecurity Framework (CSF) 2.0 to perform an effective security assessment plan. The Federal Trade Commission describes NIST as "the cybersecurity framework that helps businesses better understand, manage, and reduce their cybersecurity risk and protect their networks and data" (Federal Trade Commission, 2024). Our institute takes security practices seriously and we implement the best security practices to protect our stakeholder information.

6.2.1- Risk Addressed: Incomplete Information Security Assessment

Alpha Community College has a well-established and operated digital platform. Data stored, accessed and operated can be exposed to multiple risks, physical or virtual. NIST describes Information Security Assessment as "The testing and/or evaluation of the management, operational, and technical security controls to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for an information system or organization (Editor, n.d.).

Security Assessment is systematic and provides a framework for risk management, prevention, risk handling and business continuity. The framework considers wide ranges of security risk and provides a structured approach to tackle them.

Without a security assessment plan, Alpha Community College is exposed to greater risk to undetected vulnerabilities like data breach, phishing, DDoS and malware insertion. It can also result in failure of compliance, operational downtime and weak security plan structure. This further renders Alpha College to reactive security rather than proactive security, which leads to higher opportunity cost, weaker business continuity protocol and poor resource allocation.

6.2.2 - Initiation Rationale

Framework 2.0 is another great stride towards improving Alpha Community College's cybersecurity initiatives. The framework provides a formalized yet flexible process for identification and management of risk, thus enabling the college to conduct the required security assessments with confidence.

With NIST CSF 2.0, the institution will have explicit determination and understanding to its current vulnerabilities and threats for effective prioritization of risk. This understanding provides agency leaders with the basis to make informed decisions regarding future requirements, resourcing the most critical areas of concern.

The framework's focus is on continuous improvement and effective basis to communicate foster collaboration across departments, ensuring that everyone knows their responsibilities in maintaining a secure environment. All in all, NIST CSF 2.0 gives the college a set of tools and understandings that form a more proactive security strategy that defends its operations, reputation and stakeholders.

6.2.3 - Program Practices

To conduct an information security assessment, the 9 key steps should be taken in the following order:

1. Map assets
2. Identify security threats and vulnerabilities
3. Prioritize risks
4. Develop security controls
5. Document results
6. Create a remediation plan

7. Implement recommendations

8. Evaluate effectiveness

9. Report results

(Allen, 2021).

CSF tiers are further categorized to efficiently implement the practice. There are 4 tiers in CSF: Tier 1 (Partial), Tier 2 (Risk Informed), Tier 3 (Repeatable) and Tier 4 (Adaptive) (National Institute of Standards and Technology, 2024). They help align establishment goals with cybersecurity management practices. The CSF tiers are set at various levels depending on the sensitivity, requirements and resources, Tier 1 with the "Ad hoc" approach to cybersecurity to Tier 4 being the highly advanced practice.

As a mid-sized establishment, where cybersecurity policies are formalized and rigorously followed, risk management is proactive and processes are documented, Alpha Community College aligns with Tier 3 of the assessment guidelines.

6.2.4 - Expected Outcomes

Upon conducting and completion of the assessment, Alpha Community College is expected to have a comprehensive understanding of relevant security threats and vulnerabilities. A detailed threat landscape is designed to prioritize risk and strategies for tacking them.

6.2.4.1 - Detailed Threat and Vulnerability

As an educational institute, data as sensitive as PII, card information, biometrics and so on, is susceptible to weaknesses. For that reason, a customized landscape can be designed to meet the specified needs of our institute.

Alpha Community College further encompasses data on international students' data which are further restrictive and sensitive due to their status restrictions. Alpha Community College acknowledges such cases and intends to consider threats specific to them.

6.2.4.2 - Risk Prioritization

Risks are Prioritized based on their sensitivity and ability to impact. Data and systems are prioritized according to their nature and needs and necessary steps are taken to ensure the most efficient form of security available. The risks are prioritized based on the likelihood and scale of the threat. Alpha Community College uses NIST Risk Management Framework (RMF) for a structured risk management approach.

The chart below shows physical risk of some of Alpha Community College's infrastructure:

THREAT	VULNERABILITY	ASSET & CONSEQUENCES	RISK	SOLUTION
System failure – overheating in server room **HIGH**	Air conditioning system is ten years old **HIGH**	All services (website, email, etc.) Will be unavailable for at least three hours **HIGH**	(Potential loss of $50,000 per occurrence) **HIGH**	Buy a new air conditioner (cost: $5000)

Malicious human (interference) – distributed denial-of-service (DDoS) attack **HIGH**	Firewall configured properly and has good DDoS mitigation **LOW**	Website will be unavailable **CRITICAL**	(Potential loss of $5,000 per hours of downtime **MODERATE**	Monitor firewall
Natural disaster-flooding **MODERATE**	Server room is on the third floor **VERY LOW**	All services will be unavailable **CRITICAL**	**VERY LOW**	No action needed
Accidental human interference – accidental file deletion **HIGH**	Permissions are configured properly **LOW**	Critical data could be lost but immediately restored **MODERATE**	**LOW**	Continue monitoring permission changes, privileged users, and backups

Table 10: Physical risks

6.2.4.3 - Strategies to Tackle Risk

A roadmap is created for reducing the specified risk. These roadmaps must include whether the implementations will be short term or long term. It will also determine when it is appropriate for Alpha Community College to impose firewall enhancement, when to conduct training for the students and faculty for a “risk-awareness” culture throughout the campus district, if systems must be reconfigured or changed, and when should patch management, password resetting and other technicalities must be performed.

6.2.4.4. - Sustainable Security Plan

Continuous improvement is targeted, and strategic planning and implementation is carried out to address new changes and requirements of the institute. Sustainable cybersecurity framework is encouraged for ensuring long-term efficiency and protection.

Risk response plans must be adaptive, consistent monitoring and assessment must be done, and policies and procedures must be timely updated to aim for sustainable security plan. Moreover, crisis communication is considered as it” provides for timely, effective communication with internal and external parties” (*Risk Management and the Business Model an Analysis of UK Listed Companies and Financial Reporting Council (FRC) Model Reporting R I S K S N a P S H O T*, n.d.).

The proper communication channel provides accurate risk status, gives estimation of what needs to be done and how much time is needed to do so and therefore required for overall business continuity.

6.2.4.5 - IT and Business Alignment

The guidelines developed must align with the overall institute goals and objectives. It is the most essential aspect of guideline design and implementation. CISO and CPO are required to ensure that the framework developed fits the overall objective of the college and does not compromise any of the mission, operational objective and financial priorities.

Alpha Community College uses a framework like the RACI chart to identify clear roles and responsibility and encourages shared responsibility towards cyber issues.

6.2.5 - Implementation Timeline

Phase	Description	Estimated Duration	Comment
1	Asset Inventory and Classification	1 Month	Coordination with multiple departments required
2	Threat and Vulnerability Identification	1 Month	Budget allocation and tools allocation need to be specified
3	Risk Assessment and Prioritization	1 Month	Duration can change based on resource availability
4	Security Control Development and Implemented	2 Months	Complete security development by the first month before approval time periods (Up to one month)
5	Result Documentation	1 Week	Critical deadline

6	Remediation Plan Development and Implementation	1 Month	Cross department collaboration required
7	Recommendation Implementation	1-2 Months	Team Training required (all department)
8	Evaluation	2 Weeks	Cross department collaboration required
9	Result Reporting	1 Week	Prepared for annual compliance audit

Table 11: Implementation Timeline

6.3 - Program 3: Security Education, Awareness, and Training

The Security Education, Awareness, and Training (SEAT) program is intended to promote awareness to recognize and respond appropriately with foundational security knowledge. Practical exercises, educational programs, and awareness training will help students and staff meet cybersecurity and privacy goals and objectives. This proactive approach to a collegial environment will make cybersecurity an essential part of day-to-day campus life.

6.3.1 - Risks Addressed

The SEAT program is an effective way to ensure the reduction of the risk of human error by educating employees and contractors to implement behaviors that reduce cybersecurity risks. It mitigates these risks with enhanced end-user capabilities by creating a positive and proactive security culture within the college.

6.3.2 - Initiation Rationale

Alpha Community College has engaged and excellent administration to help students reach their best potential. The SEAT program will provide additional and necessary security to help achieve a higher potential for a cybersecurity culture that will be beneficial for all faculty and students during day-to-day campus life.

6.3.3 - Program Activities

The program should follow:

- Strategic Plan
- Strategic Goals and Objectives
- Tactics
- Continuous Improvement

6.3.3.1 - Strategic Plan

How the SEAT program aligns with the business: With the significant amount of student/faculty data, which includes financial and sensitive information, cybercriminals frequently select academic institutions as their next victims. To keep our students' and faculty's data safe, the SEAT program mitigates this risk by teaching the importance of protecting personal data to end-users and better training to admins. With enhanced end-user security knowledge, there will be a lower number of security incidents, thereby potentially reducing financial losses and keeping a high reputation among other colleges in the area.

Scope: The SEAT program range of assets includes but is not limited to: Data assets, End-user devices, Physical Assets, Email systems, HR systems, and Financial Systems. The SEAT program will affect all faculty, students, administrators, onboarding members, and everyone involved with Alpha

Community College systems and data, but with specific training levels catered to each group with different skill sets.

Key Stakeholders: The relevant stakeholders for the SEAT program are "Those with skills or expertise needed to inform the policy and operationalize it." 1 (Digital, 2020) These would include:

Stakeholder	Relevance to SEAT	Responsibility
Board of Trustees	Medium	Oversees and approves any major decisions.
CIO	High	Oversees the entire SEAT program and ensures alignment with the business.
CISO	High	Leads the SEAT program by guaranteeing the effectiveness of the program activities and policy compliance.
Faculty and Staff	High	Participation in program and involving students.
Human Resources (HR)	Medium	Helps implement the program for students and staff during the onboarding and training cycle.

IT Department	High	Implements the SEAT program and collects data for evaluation.
Student Representatives	Medium	Helps involve the student body by informing them of the program.

Table 12: Stakeholder Relevance

6.3.3.2 - Strategic Goals and Objectives:

Goal: The SEAT program aims to reduce security incidents from end users by 70% in 3 years after the continuous improvement stage.

Objectives: This will be measured by quarterly audits every semester by the IT Department.

Goal: Enhance security awareness among faculty and students to ensure they are well-informed about necessary cybersecurity practices.

Objectives: The SEAT program will be mandatory training for everyone in the Scope section. This will include any current onboarding members once the program has been passed.

6.3.3.3 - Tactics

a) Awareness Tactics: Campaigns, Workshops, and Newsletter

Start a campaign for “Cybersecurity Week”. In the first week of a month, faculty and students will all receive emails and newsletters detailing topics such as password security, cybersecurity infographics, safe browsing habits, and easy-to-remember practices that help improve the end user’s security habits online.

Posters and bulletins will be physically located where there is most traffic on the campus. This will include similar information as well as dates for workshops and cybersecurity events open to all. Every semester, Alpha Community College invites a guest speaker for a "Lunch and Learn" workshop that is open to every student and staff. Live demonstrations of how easy it can be to be hacked and following up on ways to protect yourself will leave a stronger impression among the end users.

b) Training Tactics: Hands-on Training, Simulated Scenarios

Tailored training ensures everyone is being taught for their skill set. The IT Department will implement five main training courses and where each skill group goes in their training.

Training	Students	Faculty	IT Department	Admins & Up
Password Security	✓	✓	✓	✓
Social Engineering		✓	✓	✓
Phishing Attacks	✓	✓	✓	✓
Handling Sensitive Data		✓	✓	✓
Incident Response			✓	✓

Table 13: Tailored Courses

c) Evaluation Tactics: Phishing Tests, Assessments, Performance Reviews

The IT Department will use evaluation tactics to assess how successful the SEAT program was and the impact on Alpha Community College. The audits and past assessments will be compared with the after results.

After each learning program, faculty will be regularly tested on their knowledge of password security, social engineering, phishing attacks, and more, depending on their skill set. The data from tests will be used for evaluation.

Another method of evaluation is sending out phishing emails and comparing the click rates before and after the SEAT training. Surveys will be sent out periodically. The information will be taken into consideration for future training programs during the continuous improvement phase and ongoing.

6.3.3.4 - Continuous Improvement

The IT department will analyze incoming results from evaluation methods and is encouraged to change any part of it to help improve any weak points. There will also be changes, updates, removals, and additional training that align with current standards and real-world scenarios.

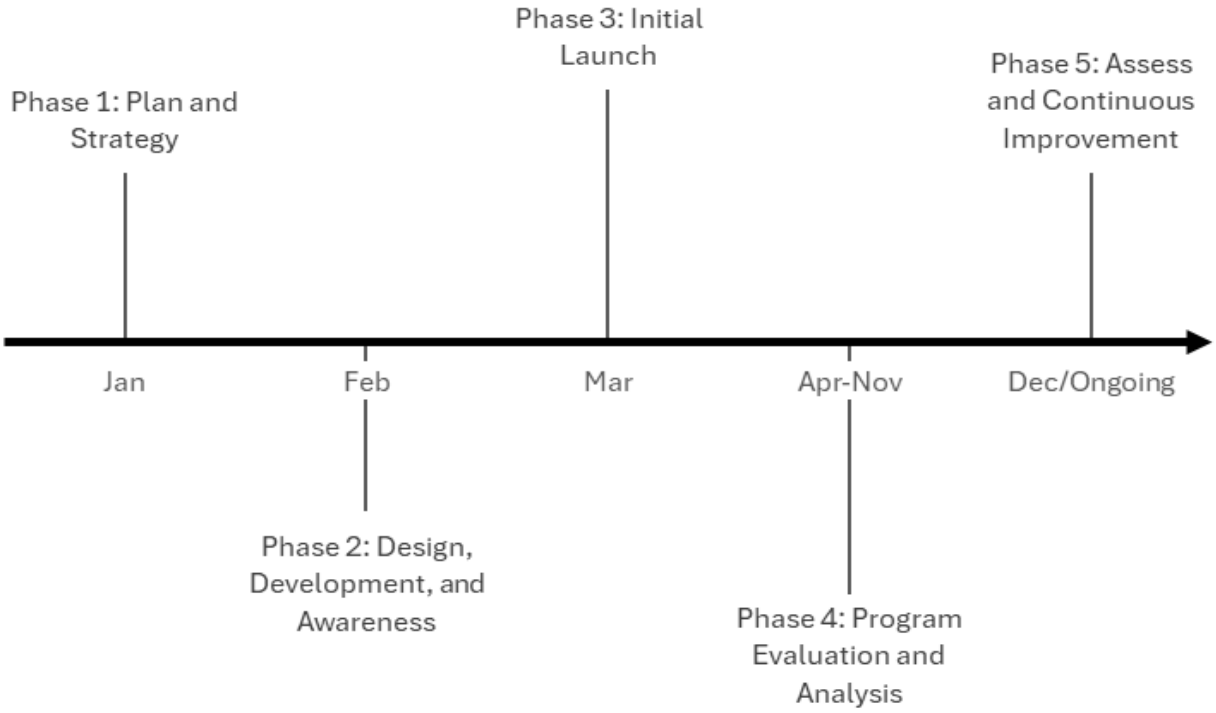
6.3.4 - Expected Outcomes

The results of the performance of the program will be sent to the Senior Leadership Committee for review. Evaluation can be determined through surveys and completion rate data. The Cybersecurity and Privacy Learning Program will have different results for other businesses, and it is up to the CPLP managers to improve this program to suit the business's needs.

6.3.5 - Implementation Timeline

The SEAT program will be deployed within six months to one year of this plan's passing, assuming it has been approved and there are enough resources to continue. It will follow the timeline:

Plan & Strategy → Analysis & Design → Development & Implementation → Assess & Improvement



Timeline 2

6.4 - Program 4: Establishing Baseline Security Controls

Alpha Community College needs to have a secure security foundation for the control baselines. Establishing security controls will greatly support the start of implementation. A cybersecurity baseline is an important set of information security standards for Alpha Community College, which helps to understand a security posture, identify security vulnerabilities, and meet the standard cybersecurity regulations (Holmes, 2024).

Another important factor in cybersecurity baseline is the connection of how security performance is directly connected to financial performance and overall business risk.

6.4.1 - Risks Addressed

Alpha Community College's Information/Cyber Security Program has not established a baseline set of security controls in which to manage the College's Information/Cyber Security Program and must establish this baseline set of security controls. Alpha Community College and those responsible for executing the Information/Cyber Security Program must substantiate implementation of their baseline set of security controls.

Establishing baseline security controls addresses several critical risks by creating a standardized approach to cybersecurity. For example, baseline controls help organizations identify and mitigate known vulnerabilities in their systems, networks, and applications, reducing the risk of exploitation by cybercriminals.

Without a defined baseline, organizations may implement inconsistent or inadequate security measures across departments, increasing vulnerability to attacks. A baseline ensures uniformity in controls and security performance across the organization. As the baseline security control relates to financial performance and business risk, the board and executives can make wise decisions on which risks are worthy to accept, mitigate, or transfer (Holmes, 2024).

6.4.2 - Initiation Rationale

Without the foundations of security baselines implemented, there is a lack of control during incidents. Alpha Community College needs to establish and define these baselines when this plan is published. Following the risk analysis graph located further below will help evaluate which security baselines to cover first and so on. This will ensure that the risks with very high impact and probability are taken care of immediately and effectively.

6.4.3 - Program Activities

6.4.3.1 - Risk Assessment

Risks are determined taking various aspects into consideration. Alpha Community College houses numerous systems and data and takes measures to access and protect it. The risk is determined in terms of what system is being compromised and prioritizing the sensitive ones for effective allocation of resources. Alpha Community College also involves its stakeholders to make sure that different perspectives are taken into account while formulating a risk assessment plan. Tools like RISK Matrix and SWOT Analysis aid systematically categorization and planning of the risks.

6.4.3.2 - Determine Scope

Alpha Community College collaborates with multiple departments while implementing a baseline security and hence identifies scope based on the collaborated effort to respect and comply with organizational policies. The compliances and regulatory requirements are also further taken into consideration as they affect how the system and its data is going to be processed.

6.4.3.3 - Map Assets

Identification and categorization of the assets is crucial to determine and budget for planning a baseline security. Some of the assets include physical workstations like servers, laptops, mobile devices, routers, printers and so forth. OS (Window, Linux), Applications and cloud services, Datas like PII (Personally Identifiable Information), backup and archival data are some of the non-tangible assets of the company.

Implemented baseline security should address all the assets, categorize them based on priority and carry out security measures to assure their projection and accessibility. A detailed asset management system is created, the lifecycle of the assets is determined and the system in question is continuously monitored to ensure compliance. Tools like ServiceNow, CMDB, SolarWinds, Nessus and Splunk can be used to manage and protect the assets.

6.4.3.4 - Identify Threats and Vulnerabilities

The college has currently identified the following threats and vulnerabilities:

- Insider Threats
- Third-Party Risk
- Hackers
- Lack of an Access Control List (ACL)
- Insufficient monitoring tools
- Absence of an incident response plan
- Need for endpoint protection

6.4.3.5 - Risk Analysis and Prioritization

The lack of an ACL, monitoring tools, incident response plan, and endpoint protection leaves the college vulnerable to insider threats, third-party risk, and hackers.

Utilizing the Risk Matrix below, the college can effectively and efficiently categorize each risk based on their likelihood and overall impact on the organization.

	Impact:	Very Low	Low	Medium	High	Very High
Probability	Very High	Moderate	Severe	Severe	Critical	Critical
	High	Sustainable	Moderate	Severe	Critical	Critical
	Medium	Sustainable	Moderate	Moderate	Severe	Critical
	Low	Sustainable	Sustainable	Moderate	Severe	Critical
	Very Low	Sustainable	Sustainable	Sustainable	Moderate	Severe

Table 14: Risk Matrix

6.4.3.6 - Evaluate and Implement Security Controls

Implementation of an effective set of baseline security controls requires the college to first evaluate existing security controls. Once the college has evaluated the current security controls, it should begin the implementation of an Access Control List (ACL), monitoring tools, incident response plan, and endpoint protection.

6.4.3.7 - Monitor and Document Results, Continuous Improvement

Findings should be documented in a report that contains sections dedicated to identified risks, including potential threats and vulnerabilities, risk prioritization, and other assessment results. Once the implementation of the set of security controls listed above is complete, KPIs should be set in place to track their effectiveness.

A performance evaluation of the security controls should be conducted quarterly. Additionally, surveys and questionnaires should be offered each quarter to gather feedback from faculty members, stakeholders, and business partners.

6.4.3.8 - Educate Staff

Staff should be educated on the purpose of the risk assessment, each security control, and the objective of Program 4. Training should be delivered through online courses, videos, and case study analysis. After completion, staff will then be required to complete an exam to demonstrate their understanding of the college's security controls. Training should be conducted on a quarterly basis.

6.4.4 - Expected Outcomes

Alpha Community College will recycle the same scorecard method to monitor the outcomes regarding the staff's understanding of risk assessment, security controls and the overall objective of program 4. By doing the scorecard we are able to track each employee as an individual and as a group allowing us to make any changes needed to the training. And to do so the overall improvements of the program will be correlated with the results from the training.

- **Online Course**
  - Rate of Participation
  - Rate of Completion
  - Information Retained
- **Training Videos**
  - Rate of Participation
  - Rate of Completion
  - Information Retained

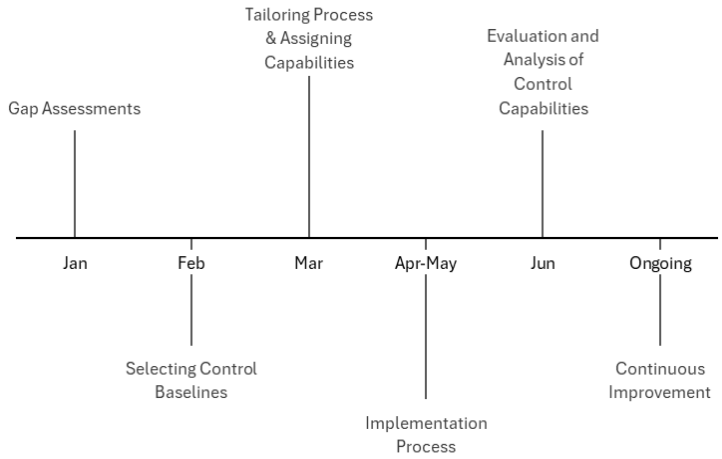
- **Case Study Analysis**
  - Rate of Participation
  - Rate of Completion
  - Information Retained
- **Understanding of Risk Assessment**
  - Exam
- **Understanding of Security Controls**
  - Exam

Example:

Domain	Perfomance Indicators	Target/Goal	Results	Measurmen	Trend	Highlights/Insights
Online Course	Rate of Participation	100%		Results		
	Rate of Completion	100%		Results		
	Information Retained	100%		Exam		
Training Videos	Rate of Participation	100%		Results		
	Rate of Completion	100%		Results		
	Information Retained	100%		Exam		
Case Study Analysis	Rate of Participation	100%		Results		
	Rate of Completion	100%		Results		
	Information Retained	100%		Exam		
Understanding of Risk Assessment	Exam	100%		Exam		
Understanding of Secuirty Controls	Exam	100%		Exam		

Table 15: Example of Scorecard

6.4.5 - Implementation Timeline



Timeline 3

Acronyms and Abbreviations

NIST – National Institute of Standards and Technology

CSF – Cybersecurity Framework

HIPPA – Health Insurance Portability and Accountability Act

FERPA – Family Education Rights and Privacy Act

COPPA – Children's Online Privacy Protection Act

PCI DSS – Payment Card Industry Data Security Standard

CIS – Center for Internet Security

FISMA – Federal Information Security Modernization Act

ISO – Internation Organization for Standardization

IEC – Internation Electrotechnical Commission

ISMS – Information Security Management Systems

GDPR – General Data Protection Regulation

SMART – Specific, Measurable, Achievable, Relevant and Time-bound

RMF – Risk Management Framework

MTTD – Mean Time to Detect

MTTR – Mean Time to Resolve

KPI – Key Performance Indicators

CPLP – Cyber Professional Liability Practitioner

SEAT – Security Education, Awareness, and Training

Definitions

Cyber Professional Liability Practitioner – A professional with specialized knowledge in cyber liability.

Cybersecurity Framework – A set of voluntary guidelines designed to help organizations assess and improve their ability to prevent, detect, and respond to cybersecurity risks.

Cybersecurity Maturity – Organization's current level of preparedness to defend against cyber threats.

Key Performance Indicators – A type of performance measurement. KPIs evaluate the success of an organization or of a particular activity in which it engages.

Key Stakeholders – Are people or group of people that are most important and involved within the success of a project in an organization.

Phishing Attack – A type of attack where attackers relay fraudulent communications with the goal of installing malware or stealing sensitive information.

Scope – In this document, scope is used to define the extent of who is involved within a program.

Social Engineering – A broad type of attack that takes advantage of human nature through human interactions for malicious intentions.

Works Cited

"7 Steps to Effective Data Classification." *Www.cdw.com*, www.cdw.com/content/cdw/en/articles/security/7-steps-to-effective-data-classification.html.

Achieving CIS Controls Maturity in OT Systems. Ganzer, M. (2020, November 8). Verve Industrial. https://verveindustrial.com/resources/case-study/cis-top-controls/.

A Detailed Guide to NIST 800-53 Standard (2024 Updated). Gracy, M. (2024, February 16). Sprinto. https://sprinto.com/blog/nist-800-53-guide/.

Alder, S. (2024). *What are the Penalties for HIPAA Violations?* HIPAA Journal. https://www.hipaajournal.com/what-are-the-penalties-for-hipaa-violations-7096/.

Allen, Josh. "How to Conduct a Security Risk Assessment." *PurpleSec*, 25 Sept. 2021, purplesec.us/learn/security-risk-assessment/.

Andales, J. (2024, September 12). *Risk Assessment Guide & Template Collection*. SafetyCulture. https://safetyculture.com/topics/risk-assessment/.

Brook, C. (2023, March 23). *Data Classification Examples to Help You Classify Your Sensitive Data*. Digital Guardian. https://www.digitalguardian.com/blog/data-classification-examples-help-you-classify-your-sensitive-data.

CEO roles and responsibilities: Key functions in 2024. NorthWest Executive Education. (2024, October 22). https://northwest.education/insights/careers/chief-executive-officer-ceo-roles-responsibilities/.

Chief executive officer (CEO)-roles and Responsibilities. Coursera Staff. (2024, November 5). Coursera. https://www.coursera.org/articles/what-is-a-ceo.

CIS Critical Security Controls v8: Overview, Updates, and What They Mean for Your Business. Kitework. (n.d.). Kiteworks | Your Private Content Network. https://www.kiteworks.com/risk-compliance-glossary/cis-controls-v8/.

CISO roadmap playbook – first 101 days CISO. Fimlaid, J. (2024, May 17). NuHarbor Security. https://www.nuharborsecurity.com/blog/first-101-days-new-ciso-chief-information-security-officers-playbook.

Cisco. (2022, December 7). What is a CISO? chief information security officer. Cisco. https://www.cisco.com/c/en/us/products/security/what-is-ciso.html#~ciso-role-explained.

Claroty. (2023, August 20). Cybersecurity 101: A Guide to the NIST Cybersecurity Framework. Claroty. https://claroty.com/blog/nist-cybersecurity-framework.

College, N. C. (2024). *Mission, Vision and Values | Northampton Community College*. Northampton.edu. https://www.northampton.edu/about/mission-vision-and-values/index.html.

"Cybersecurity Gap Analysis." *CyberMaxx*, www.cybermaxx.com/cybersecurity-services/governance-risk-and-compliance/cybersecurity-gap-analysis/.

Data Classification and Handling Procedures Guide | Policy Library. (n.d.). Policy.ku.edu. https://policy.ku.edu/IT/data-classification-handling-procedures.

Data classification examples: Data types and policies. Satori. (2023, April 22). https://satoricyber.com/data-classification/data-classification-examples-data-types-and-policies/#:~:text=Examples%20of%20restricted%20data%20include,related%20data%2C%20and%20cardholder%20data.

Data Classification Policy Template. (n.d.). Netwrix. https://www.netwrix.com/data_classification_policy_template.html.

Data Protection officer (DPO). European Data Protection Supervisor. (2024, December 4). https://www.edps.europa.eu/data-protection/data-protection/reference-library/data-protection-officer-dpo_en.

"Data Remanence - an Overview | ScienceDirect Topics." *Www.sciencedirect.com*, www.sciencedirect.com/topics/computer-science/data-remanence.

Developing a Cybersecurity Scorecard. (n.d.). https://csrc.nist.gov/CSRC/media/Presentations/Creating-a-Cybersecurity-Scorecard/images-media/Developing%20a%20Cybersecurity%20Scorecard.pdf.

Director of information technology. Kirtland Community College. (n.d.). https://www.kirtland.edu/human-resources/job-descriptions/director-of-information-technology/.

Durham-Hutchins, L. (2024, January 17). *Who is responsible for data protection in a company?* DPAS. https://www.dataprivacyadvisory.com/who-is-responsible-for-data-protection-in-a-company/.

Editor, C. C. (n.d.). Security assessment - Glossary | CSRC. Csrc.nist.gov. https://csrc.nist.gov/glossary/term/security_assessment.

Emma. [Excel Dictionary]. (2024, Aug 7) *How to Create a Timeline Chart in Excel* [Video] Youtube. https://youtu.be/JFzJV3I5Wgk?si=eSQiJX8q_pLTLele

Family Educational Rights and Privacy Act (FERPA). CDC. (2024, May 13). Public Health Law. https://www.cdc.gov/phlp/php/resources/family-educational-rights-and-privacy-act-ferpa.html.

Federal Communications Commission · Consumer and Governmental Affairs Bureau · 445 12th St. SW. Washington, DC 20554 1-888-CALL-FCC (1-888-225-5322) · TTY: 1-888-TELL-FCC (1-888-835-5322) · www.fcc.gov/consumer-governmental-affairs-bureau. (n.d.). https://www.fcc.gov/sites/default/files/childrens_internet_protection_act_cipa.pdf.

Federal Trade Commission. (2024). Understanding the NIST cybersecurity framework. Federal Trade Commission. https://www.ftc.gov/business-guidance/small-businesses/cybersecurity/nist-framework.

Finding the right general counsel for your college or university. Crosse, S. (2024, October 30). The Global Navigators of Legal Careers. https://www.mlaglobal.com/en/insights/articles/finding-the-right-general-counsel-for-your-college-or-university.

GDPR. (2018). Personal Data | General Data Protection Regulation (GDPR). General Data Protection Regulation (GDPR). https://gdpr-info.eu/issues/personal-data/.

Hameed, Manny. "Information Security Project Lab---Alpha Community College Version 1." Information Security Project Plan Lab/Exercise [Collin College Frisco], PowerPoint presentation, 28 Nov 2024.

IBM. (2022). *What are Security Controls? | IBM*. Www.ibm.com. https://www.ibm.com/topics/security-controls.

Identity Theft Enforcement And Protection Act | Office of the Attorney General. (n.d.). Www.texasattorneygeneral.gov. https://www.texasattorneygeneral.gov/consumer-protection/file-consumer-complaint/consumer-privacy-rights/identity-theft-enforcement-and-protection-act.

Information Security Governance | Security Program and Policies: Governance and Risk Management | Pearson IT Certification. Pearson IT certification. (2014, April 16). https://www.pearsonitcertification.com/articles/article.aspx?p=2192704&seqNum=2.

Internal Audit in Higher Education Institutions. Bucklin, A. (2024, November 21). CapinCrouse LLP. https://capincrouse.com/internal-audit-in-higher-education-institutions/.

"ISO 27701 Certification: Privacy Information Management | DNV." *DNV*, 2024, www.dnv.com/services/iso-iec-27701-privacy-information-management-system-159186/.

ISO/IEC 27001 standard – information security management systems. ISO. (2022). ISO. https://www.iso.org/standard/27001.

Kirvan, Paul, and Joseph Granneman. "Top 7 IT Security Frameworks and Standards Explained." *SearchSecurity*, Dec. 2021, www.techtarget.com/searchsecurity/tip/IT-security-frameworks-and-standards-Choosing-the-right-one.

Kissel, R., Scholl, M., Skolochenko , S., & Li, X. (2006, September). NIST SP 800-88, Guidelines for Media Sanitization. https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=50819.

Klaino. (2024, November 12). The essential role of Internal Audit In Higher Education. Cerini & Associates, LLP. https://ceriniandassociates.com/internal-audit-higher-education/.

Knowles, Mark. "Cybersecurity Risk Management: Frameworks, Plans, & Best Practices." *Hyperproof*, 8 Sept. 2021, hyperproof.io/resource/cybersecurity-risk-management-process/.

Medical director: Job description and salary. Online Masters in Public Health. (n.d.). https://mphdegree.usc.edu/public-health-careers/medical-director.

Merritt, Marian. *Building a Cybersecurity and Privacy Learning Program*. 1 Jan. 2024, csrc.nist.gov/pubs/sp/800/50/r1/final, https://doi.org/10.6028/nist.sp.800-50r1.

Merritt M, Hansche S, Ellis B, Sanchez-Cherry K, Snyder JN, Walden D (2024) Building a Cybersecurity and Privacy Learning Program. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-50r1. https://doi.org/10.6028/NIST.SP.800-50r1.

Michelle Kaminsky, J. D. (2023, November 8). Roles and duties of Your Board of Trustees. LegalZoom. https://www.legalzoom.com/articles/roles-and-duties-of-your-board-of-trustees.

"Mission and Goals." *Community College of Philadelphia*, 7 Aug. 2013, www.ccp.edu/about-us/mission-and-goals.

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. The NIST Cybersecurity Framework (CSF) 2.0, 2.0(29). https://doi.org/10.6028/nist.cswp.29

National Institute of Standards and Technology. (n.d.). Risk management framework categorize step. Retrieved from https://csrc.nist.gov/Projects/risk-management/about-rmf/categorize-step

National Institute of Standards and Technology. (n.d.). Risk management framework select step. Retrieved from https://csrc.nist.gov/Projects/risk-management/about-rmf/select-step

National Institute of Standards and Technology. (n.d.). Risk management framework implement step. Retrieved from https://csrc.nist.gov/Projects/risk-management/about-rmf/implement-step

National Institute of Standards and Technology. (n.d.). Risk management framework assess step. Retrieved from https://csrc.nist.gov/Projects/risk-management/about-rmf/assess-step

National Institute of Standards and Technology. (n.d.). Risk management framework authorize step. Retrieved from https://csrc.nist.gov/Projects/risk-management/about-rmf/authorize-step

National Institute of Standards and Technology. (n.d.). Risk management framework monitor step. Retrieved from https://csrc.nist.gov/Projects/risk-management/about-rmf/monitor-step

National Institute of Standards and Technology. "Security and Privacy Controls for Information Systems and Organizations." *Security and Privacy Controlsfor Information Systems and Organizations*, Sept. 2020, nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf, https://doi.org/10.6028/nist.sp.800-53r5.

---. "The NIST Cybersecurity Framework (CSF) 2.0." *The NIST Cybersecurity Framework (CSF) 2.0*,

26 Feb. 2024, nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf, https://doi.org/10.6028/nist.cswp.29.

NIST. (2016, November 30). *NIST Risk Management Framework*. NIST. https://csrc.nist.gov/projects/risk-management/about-rmf.

NIST. "Control Baselines for Information Systems and Organizations." *Control Baselines for Information Systems and Organizations*, 28 Oct. 2020, nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53B.pdf, https://doi.org/10.6028/nist.sp.800-53b.

---. "NIST Risk Management Framework." *Nist.gov*, 2014, csrc.nist.gov/Projects/Risk-Management.

Qureshi, Azam. "Data Retention Policy 101: Best Practices, Examples & More." *Intradyn*, 25 Sept. 2020, www.intradyn.com/data-retention-policy/.

PIPEDA in brief - Office of the Privacy Commissioner of Canada. Office of the Privacy Commissioner of Canada. (2024, May 1). Priv.gc.ca; Office of the Privacy Commissioner of Canada. https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/.

Price, W. by N., & Price, N. (2019, January 4). Roles & responsibilities of a Board of Directors for a college. BoardEffect. https://www.boardeffect.com/blog/roles-responsibilities-board-directors-college-university/.

Rachel Holmes. (2024, June 21). *How to Establish a Cybersecurity Baseline That Works for Your Organization*. Bitsight. https://www.bitsight.com/blog/establish-cybersecurity-baseline.

Raina, Kapil. "Zero Trust Security Explained | Principles of the Zero Trust Model." *Crowdstrike.com*, CrowdStrike, 17 Apr. 2023, www.crowdstrike.com/cybersecurity-101/zero-trust-security/.

Redirecting... (2024). Heinonline.org. https://heinonline.org/HOL/Page?handle=hein.journ.

Robinson, P. (2019, September 10). *How to Build a Data Classification Policy to Improve Data Security*. Lepide Blog: A Guide to IT Security, Compliance and IT Operations. https://www.lepide.com/blog/how-to-build-a-data-classification-policy/.

Siddiqui, Maahnoor. "A Pocket Guide to Factor Analysis of Information Risk (FAIR)." *Www.cybersaint.io*, 2024, www.cybersaint.io/blog/a-pocket-guide-to-factor-analysis-of-information-risk-fair.

Ticong, L. (2024, February 16). *Data Classification Policy: Ultimate Guide (+Template)*. Datamation. https://www.datamation.com/big-data/data-classification-policy/.

Tunggal, Abi Tyas. "14 Cybersecurity Metrics + KPIs to Track." *Www.upguard.com*, 22 May 2023, www.upguard.com/blog/cybersecurity-metrics.

Tunggal, A. T. (2023, October 24). *How to Perform a Cybersecurity Risk Assessment (2023 Guide) | UpGuard*. Www.upguard.com. https://www.upguard.com/blog/how-to-perform-a-cybersecurity-risk-assessment.

University, EC-Council. "How Well Aligned Information Security Programs Help Business Grow." *Cybersecurity Exchange*, 30 Nov. 2022, www.eccouncil.org/cybersecurity-exchange/executive-management/information-security-programs-grow-businesses/.

What are Data Security Controls ? (2024, May 30). Centraleyes. https://www.centraleyes.com/glossary/data-security-controls/.

"What Is Risk Prioritization." *Centraleyes*, www.centraleyes.com/glossary/risk-prioritization/.

Collaboration